

PrimusCredence

Provable Security for
Apps & AI Agents

primuscredence.com

UAE

Dr. Raghavendra Ramesh

Founder & CEO, PrimusCredence

22+ YEARS OF EXPERIENCE IN PROVABLE SECURITY

PhD, IISc Bangalore

Model checking for information-flow security

Oracle Labs · 2014–2019

Java vulnerability detection

ConsenSys R&D · 2019–2021

Cross-chain protocols, consensus verification

Supra · VP of R&D · 2021–ongoing

BFT design & FV, bridges, DeFi

TECHNIQUES

Static analysis, theorem proving,
model checking

TOOLS

Dafny, TLA+, IVy, Lean, Isabelle

Why Now: The Attacker Industrialised

A sampling defence cannot answer an enumerating attack.

4.5×

revenue of AI-assisted scam operations versus non-AI equivalents

\$3.52

average compute cost per LLM-agent exploit attempt on a real CVE

87%

of a 15-CVE sample exploited from the public description alone

TRADITIONAL PEN TEST

10^2 – 10^3 paths, human-selected
2–4 week window, then closed
High marginal cost per path
“We found no way in”

AI-DRIVEN ADVERSARY

10^5 – 10^7 paths, machine-enumerated
Continuous, no window
Near-zero marginal cost
Approaching exhaustive

Proof is the one capability that answers exhaustive search in kind.

Automated Reasoning

Proof establishes that bad things cannot happen.

1

Formalise

Your existing artefact becomes a logical model

2

State

The security property becomes a formula

3

Solve

Z3, CBMC, Batfish, IVy and TLA+ search it all

4

Report

A proof, or a reproducible attack path

✦ AI - POWERED ✦

UNSAT

No violating state exists — over the entire space, under a stated model.

Not “none was found”.

SAT + witness

The exact request, path or call ordering that breaks it — reproducible on your estate.

Industrial practice: AWS (Zelkova, Tiros, Nitro) · Microsoft (Z3) · Meta (Infer) · Airbus (Astrée)

We Add a Layer to Your Stack, NOT Replace It

WHAT YOUR STACK ANSWERS TODAY

Pen test & red team

CSPM / CIEM

ASPM / SAST

Vulnerability management

SOC · EDR · SIEM

“We looked, and within the time available we did not find a way in.”

WHAT WE ADD

“No way it exists — over the whole modelled space.”

A preventive control with evidence behind it, re-run on every change.

WHAT STAYS WITH YOU

Configuration drift, shadow assets and anything outside the model

Insider misuse, and valid credentials used exactly as intended

Detection, response and the rest of the programme you already run

Six Solutions, Two Families

Cybersecurity

CISO · cloud security
· AppSec

- 1 Cloud entitlement proofs
- 2 Network segmentation proofs
- 3 Application & API conformance
- 4 Post-quantum migration

AI Security

Head of AI · model
risk

- 5 Agentic guardrail verification
- 6 Hallucination / entailment checks

Cybersecurity Solutions

- 1 Cloud access-policy and entitlement verification
- 2 Network reachability and segmentation proofs
- 3 Application and API-usage conformance
- 4 Post-quantum cryptography migration

1. Cloud Access-Policy & Entitlement Verification

Can any principal, in any request context, reach this resource from outside the trust boundary?

THE PROBLEM

IAM is combinatorial: the effective permission composes policies, boundaries, SCPs and request context. CIEM scores the paths it enumerated.

PRECEDENT AWS Zelkova → IAM Access Analyzer
BUYERS Regional CSPs · sovereign hosts

WHAT WE BUILD

- Multi-cloud policies into one logical model
- Privilege-escalation paths across the graph
- Cedar symbolic checks as a CI/CD gate

OUTPUT

Proof of safety over all requests — or the violating request, the escalation path it opens, and its blast radius.

2. Network Reachability & Segmentation Proofs

Does any path exist from an untrusted zone to this subnet — and does east-west segmentation hold?

THE PROBLEM

Probing tests the paths you thought of, at the moment you ran it. Reachability is a property of the configuration, not of the packets sent.

Static: no scanning window, no production traffic — it re-runs on every change.

PRECEDENT AWS Tiros → VPC Reachability Analyzer

BUYERS Sovereign cloud · banks · OT · telcos

WHAT WE BUILD

- Batfish models of the hybrid and on-prem estate
- Soufflé and Z3 engines for cloud topologies
- Microsegmentation vs. the declared policy

OUTPUT

A proof that no path exists — or the path, hop by hop, with the rule that permits it and the owner of that rule.

3. Application and API-Usage Conformance

Does our own code use the APIs it is built on — cloud, credential and crypto SDKs, and its own data-access calls — the way their contracts

THE PROBLEM

Cloud and app APIs are protocols, not calls. Undrained pagination, a logged credential, an object fetched by request ID without an ownership check — all compile and pass review. Same risk

A correct policy invoked through a misused SDK still leaks. Bounded by the library.

PRECEDENT AWS RAPID → CodeGuru · 76% accepted
BUYERS Platform and AppSec teams · ISVs

WHAT WE BUILD

- Object-ownership (BOLA/IDOR) and auth-routing patterns
- A conformance gate for library publishers
- PR-gate CI on Soot, CodeQL and Infer

OUTPUT

The call site, the taint trace, the pattern violated and the corrected call sequence — plus which patterns were checked.

4. Post-Quantum Cryptography Migration

On an already quantum-safe cloud, does the app's integration still authenticate the right party in every session?

THE PROBLEM

The cloud's PQC transport can be formally proven and the app on top still relayed or downgraded. Hybrid migration adds identity-binding and combiner failures that code review ships past.

Verified app crypto on an already-verified cloud — proof end to end.

PRECEDENT PQ-SSH counterexample, then proved (2024)

BUYERS Gov ID · PKI · banks · healthcare · defence

WHAT WE BUILD

- Discovery and a versioned CBOM, gaps listed
- The app-to-cloud integration protocol, transport proof discharged
- Identity, channel and downgrade binding, over all sessions

OUTPUT

The CBOM and a sequenced plan; then a proof the app's integration preserves authentication and secrecy on the verified base — or the relay that breaks it.

AI Security Solutions

- 5 Agentic guardrail verification — what an agent may do
- 6 Neurosymbolic assurance — what an agent may say

5. Agentic AI Guardrail Verification

Not “how often does the agent fail?” but “can it do this at all?”

THE PROBLEM

An agent is a non-human identity with delegated privilege and an instruction channel the adversary can write to. A guard model judging a model is detective, not preventive.

Provable: no rows outside the caller's ACL.
Not provable: no PII ever reaches the user.

PRECEDENT Bedrock Automated Reasoning
BUYERS Banks · sovereign AI · OT · healthcare

WHAT WE BUILD

- Tool-call constraints over identity and arguments
- Data-access boundaries in the Solution 1 logic
- Composition safety across call sequences

OUTPUT

A result about the mediation layer, not the model: nothing permitted escapes the envelope, and no path bypasses it.

6. Neurosymbolic Assurance

Does this answer follow from the policy we operate under — and if not, what assumption was silently supplied?

THE PROBLEM

Solution 5 bounds what an agent may do; nothing bounds what it may say. This is hallucination — an entailment failure: no boundary crossed, liability all the same.

LLM autoformalization drafts the theory; the domain expert ratifies it.

PRECEDENT Bedrock Automated Reasoning checks
BUYERS Banks and insurers · government

WHAT WE BUILD

- Policy theory development, scope stated
- Entailed / contradicted / unsupported verdicts
- An evaluation harness on the client's corpus

OUTPUT

Per answer: the verdict, the derivation or the contradicting rule, and the missing assumption named — an audit trail.

Why Your Clients Will Ask

Four things happened at once in the GCC.

Mandatory replaced voluntary
UAE cyber-resilience obligations now carry penalties of AED 100k–3m.

Assurance shifted to evidence
Regulators increasingly ask for demonstrable control effectiveness, not attestation.

AI rules arrived before AI assurance
Risk-tiered obligations demand evidence the market cannot yet produce.

Sovereignty is a reachability question
Localisation asks whether regulated data can leave. Solution 2 settles it.

WHERE A FINDING ALSO LANDS					
DESC ISR	1 2 3	NESA / UAE IAS	2	UAE PDPL	2 3 5
SAMA CSF	1 2 3 5	NCA ECC	1 2 3	UAE AI Act	5 6
ISO 27001	1 2 3 4	ISO 42001	5 6	NIST CSF 2.0	1–4

Regulation routes the finding to a second reader. It is not the reason to commission it.

What a Provider Can Resell

We do not certify — so an audit firm or an MSSP is a channel, not a rival.

Scanning · posture reporting · monitoring



Provable control effectiveness

THE COMMERCIAL MOVE

- Specialist capability inside bids you already win
- You keep the client relationship and the contract

WHY IT DEPLOYS EASILY

- Read-only access, no agent on any host
- No scanning window, no production traffic

Read-only and agentless, so it clears change advisory in one pass.

We produce the technical evidence. Your assessor keeps the opinion.

One Result, Three Registers

First line

Engineering and security operations

The property, its model and assumptions, and either the proof or a reproducible attack path.

Second line

Risk

Likelihood moved off a qualitative guess, with residual risk and the model's limits stated.

Third line

Internal audit and compliance

A clause-mapped control assertion: objective, status, owner and re-verification date.

✓ Design → operating effectiveness · attaches to your GRC records · assessors probe less

The first register is the product. The second and third make it worth more than it cost.

Investment

Early-stage — we raise to prove the method, not to scale ahead of proof.

Feasibility studies

Validate each solution on real client artefacts — a claim becomes a proof, or a counter-example, on systems that matter.

- De-risk the six solutions on live estates
- Turn research into productised checks
- Reference results to show the next buyer

Pilot projects

Co-funded pilots with named design partners: one narrow, high-risk slice, delivered end to end.

- Paid proofs-of-value with design partners
- Read-only and agentless — fast to deploy
- Each pilot becomes a reusable case study

USE OF FUNDS — EVIDENCE FIRST

Feasibility studies and pilot projects. Detailed figures and milestones on request.

Take Away

**Mathematical rigour to security —
proof alongside testing, across cloud, apps and AI.**

The shift

Attack path discovery is automated, parallel and cheap. A defence that only samples cannot answer one that enumerates.

The addition

We do not replace testing, monitoring or the SOC. We make one class of controls machine checkable.

The honesty

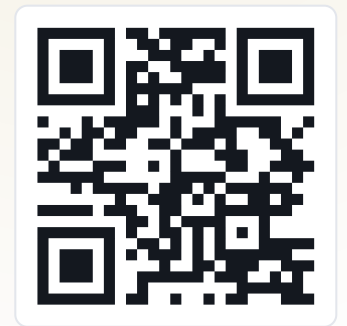
A proof is relative to a model and a specification — both stated. We produce the evidence; we do not certify.

START HERE — MICRO ASSESSMENT OF SOLUTION 1

One narrow, high-risk slice. Read-only access, no agent deployed, weeks not months — and a counter-example on your own systems, or a proof.

Thank You

*Let us prove one property on your estate —
then judge the method on the result.*



primuscredence.com

Dr. Raghavendra Ramesh

Founder & CEO, PrimusCredence
PhD, IISc Bangalore

raghavendra@primuscredence.com

+971 58 189 2803
UAE

Cloud | Apps | AI Agents